PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Méthodologie DevSecOps

03-280 ANSSI - DevSecOps — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'analyse de risque doit intégrer les chemins de compromission incluant les postes développeurs, la sous-traitance et la chaîne CI/CD.
2. Les actions de la CI/CD de production doivent être traitées comme des actions d'administration avec un poste dédié et le principe de moindre privilège.
3. L'intégrité des artefacts doit être maintenue de bout en bout par la signature et la vérification des tags de version.

Cartographie et analyse de risque

Notion	À retenir
Cartographie applicative	Doit être **maintenue à jour** : inclut droits système, **secrets**, matrices de flux, rôles, relecture, validation, droits environnements et **référents** (technique/métier).
Analyse de risque	Doit prendre en compte les **chemins de compromission** : postes développeurs, **sous-traitance**, chaîne **CI/CD** et technologies (ex: **cloud**).

Sécurisation de la chaîne CI/CD de production

Notion	À retenir
Actions CI/CD production	Considérées comme des **actions d'administration** : dédier un **poste d'administration**, appliquer le **moindre privilège**, générer des **jetons/tokens à la demande**, **journaliser** et **superviser**.
Gestion des secrets	Utiliser un **gestionnaire de secrets distinct** par environnement (**hors production** et **production**). **Aucun secret en dur** dans le code source, les journaux d'événements ou les dépôts.
Gestion des dépendances	Les dépendances doivent être **gérées avec rigueur**, **minimisées**, **évaluées**, et les **correctifs de sécurité appliqués** avant déploiement.

Tests et déploiement sécurisés

Notion	À retenir
Tests automatisés CI/CD	Prévoir des tests de **non-régression**, d'**étanchéité** (profils utilisateurs), d'**analyse statique et dynamique**, et de **conformité** de l'**infrastructure as code**.
Sécurisation déploiement	Maintenir l'**intégrité du code source** de bout en bout ; **signer** et **vérifier les signatures** des **tags de version** des artefacts.

Authentification et infrastructures CI/CD

Notion	À retenir
Authentification multifacteur	Doit être implémentée pour l'**accès aux dépôts** et pour la **signature des commits**.
Séparation et renouvellement	CI/CD de **développement** et de **production** séparées, **non exposées** directement sur Internet ; **réinstanciation régulière**, **sans données persistantes**.
Confidentialité et durcissement	Vigilance sur la **localisation** de la CI/CD et le test du code en **SaaS public** ; **règles de développement sécurisé** ; **durcissement** des OS hébergeant les applications.

Pièges et confusions

- ⚠ Considérer les actions de la CI/CD de production comme de simples actions d'intégration continue plutôt que des actions d'administration.
- ⚠ Oublier de réinstancier régulièrement l'infrastructure CI/CD sans données persistantes pour limiter l'impact d'une compromission.
- ⚠ Stocker des secrets en dur dans le code source, les journaux d'événements ou les dépôts.
- ⚠ Utiliser un gestionnaire de secrets unique pour tous les environnements au lieu d'un gestionnaire distinct par environnement.
- ⚠ Négliger la conformité de l'infrastructure as code lors des tests automatisés.

Sigles et définitions

DevSecOps	méthodologie visant à inclure les pratiques de sécurité dans le processus de développement et de mise en production d'applications
CI/CD	Continuous Integration et Continuous Deployment comprenant un orchestrateur, des dépôts, des tests, un gestionnaire de secrets, des outils de déploiement et des artefacts
IaC	Infrastructure as Code, pratique consistant à décrire l'infrastructure sous forme de code
Artefact	résultat produit par la chaîne CI/CD
Authentification multifacteur	méthode devant être implémentée pour l'accès aux dépôts et pour la signature des commits

Auto-test

1. Que doit-on faire pour l'intégrité des artefacts ?
2. Où ne faut-il jamais mettre de secrets ?
3. Comment doit être gérée l'infrastructure CI/CD pour éviter qu'un attaquant ne se maintienne durablement ?
4. Quels types de tests automatisés doit-on prévoir en CI/CD ?
5. Que doit inclure la cartographie applicative ?

Réponses : **1.** Signer et vérifier les signatures des tags de version · **2.** Dans le code source, les journaux d'événements ou les dépôts · **3.** Par une réinstanciation régulière sans données persistantes · **4.** Non-régression, étanchéité, analyse statique et dynamique, et conformité de l'IaC · **5.** Droits système, secrets, matrices de flux, rôles, relecture, validation, droits environnements et référents

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.